



NCIIPC NEWSLETTER

JULY 2025

National Critical Information Infrastructure Protection Centre
(A unit of National Technical Research Organisation)



NCIIPC **Startup India** AI GRAND CHALLENGE

Responsible AI for National Security

An initiative to encourage Deep Tech Startups to build indigenous Products/Solutions to the Challenges in the National Security domain

Challenge Highlights

- 12 Problem Statements (PS) relating to AIML in Cybersecurity & Forensics, Bigdata Analytics, Geospatial, Cryptology, Maritime and OSINT domains.
- Total Prizes worth **₹22.56 Crore**

Prizes per Problem Statement
 - ₹5.76 Crores in Stage-1,
 - ₹10.8 Crores in Stage-2, and
 - ₹6 Crores in Stage-3.
- Nationally renowned Mentors to guide and facilitate Startups to solve the problems.



NCIIPC Newsletter

July 2025



Message from the NCIIPC Desk

Dear Readers,

NCIIPC continues its effort to make our stakeholders more cyber security aware through our Newsletter for this quarter with updates on national and international topics.

Inside This Issue

- 1 **Message from NCIIPC Desk**
- 2 **Policy & Strategy**
- 2 **Trends**
- 3 **Malware Bytes**
- 9 **Vulnerability Watch**
- 13 **News Snippets – National**
- 14 **News Snippets – International**
- 17 **Security App**
- 19 **Learning**
- 25 **Mobile Security**
- 27 **NCIIPC Initiatives**
- 29 **Events – India**
- 29 **Events – Global**
- 31 **Abbreviations**
- 32 **Sources**

NCIIPC has launched Startup India AI Grand Challenge on 1st July 2025. The NCIIPC Startup India AI Grand Challenge is a pioneering initiative to encourage Deep Tech Startups to build indigenous Products/Solutions to the Challenges in the National Security domain. Indian Startups and Student Groups working in Artificial Intelligence are invited to join this challenge to provide innovative solutions for various problem statement.

In this quarter, major initiatives have been seen in Indian cyber space that includes the Reserve Bank of India (RBI) direction to all commercial banks, urban cooperative banks, state cooperative banks, and district central cooperative banks to begin shifting their digital infrastructure to the new '.bank.in' domain, the Ministry of Home Affairs' (MHA) Indian Cybercrime Coordination Centre (I4C) e-Zero initiative to auto-register high-value cybercrimes, the Maharashtra government has announced the formation of the Maharashtra Cyber Crime Security Corporation (MCCSC), established under the Companies Act, 2013, and the Department of Telecommunications (DoT) programme on Financial Fraud Risk Indicator (FRI) under the Digital Intelligence Platform (DIP) to strengthen cyber fraud prevention efforts in India.

At international level, initiative by Japan on Active Cyber Defense (ACD) Law, an active approach to national cybersecurity has been covered.

Suggestions/Feedback from the readers are welcome. Please do write to us at newsletter@nciipc.gov.in. The important suggestions /feedback received shall also be published.

Policy & Strategy

Japanese Parliament Passes Active Cyber Defense Law

Japan has enacted the Active Cyber Defense (ACD) Law, an active approach to national cybersecurity. The ACD Law is part of Japan's broader effort to address the increasing frequency and sophistication of cyberattacks, especially amid a national shortage of cybersecurity professionals. This new legislation empowers government bodies, such as the National Police Agency and the Self-Defense Forces, to detect and counteract cyber threats originating from outside the country. By allowing the monitoring of international internet traffic, the law aims to identify and disrupt potential attacks before they reach Japan, so that domestic communications remain protected under constitutional privacy rights. The law also introduces mandatory reporting for cyber incidents. In cases where threats are confirmed, authorities are authorised to take proactive steps, including disabling foreign servers involved in malicious activities. To maintain transparency and accountability, an independent review board will oversee any surveillance or countermeasures conducted under this law.

This new legislation empowers government bodies, such as the National Police Agency and the Self-Defense Forces, to detect and counteract cyber threats originating from outside the country.

Trends

Deepfake Deception: The New Frontier of Social Engineering Cybercrime

Phishing attacks have evolved significantly, moving beyond just suspicious links and fake email domains. Today, deepfake-driven social engineering is one of the most rapidly growing cybersecurity threats. These attacks utilise AI-generated audio and video to impersonate trusted contacts, bypassing traditional email defences and targeting human trust directly. Deepfakes have quickly gone from concept to a major threat, growing exponentially.

The success of these attacks lies in their ability to exploit emotional responses, making it difficult for people to distinguish between real and AI-generated individuals. Attackers leverage instincts like trust in authority and urgency, creating highly realistic impersonations of executives or colleagues requesting urgent help. Even well-trained employees can fall victim to these attacks, which can result in ransomware, data theft, or persistent insider access that leads to further breaches.

Traditional email security solutions are inadequate against modern phishing tactics. These outdated systems focus primarily on attachment scanning and domain checks, which fail to detect deepfakes using real-time video or AI-generated voices.

These attacks utilise AI-generated audio and video to impersonate trusted contacts, bypassing traditional email defences and targeting human trust directly.

To combat deepfake-enabled phishing, organisations need a multi-layered security approach. This includes AI-powered detection of synthetic media, real-time threat intelligence, and behavioural analytics to spot impersonation. Effective defences also rely on user awareness training, continuous threat modelling, and expert-driven security configuration.

Microsoft Launches Free EU Cybersecurity Program to Counter State-Sponsored Threats

Microsoft has unveiled a new European Security Program designed to enhance cybersecurity across EU governments. Announced in Berlin, the program is free for all EU countries, including the UK, Monaco and the Vatican to combat state back actors from adversary nation.

The company highlighted the increasing espionage activities targeting European networks focused on credential theft and exploiting vulnerabilities in government and corporate systems.

A central feature of the initiative is AI-driven cyber-defence, providing real-time threat intelligence and updates tailored to each country's needs. Microsoft will also offer early warnings on vulnerabilities, focusing on deepfake influence operations and malware outbreaks.

The program strengthens partnerships with Europol, the CyberPeace Institute and others, aiming to disrupt cybercrime and provide expert guidance on remediation. Microsoft's recent success in taking down the Lumma malware highlights its commitment to securing Europe's digital infrastructure.

A central feature of the initiative is AI-driven cyber-defence, providing real-time threat intelligence and updates tailored to each country's needs.

Malware Bytes

Disk-Wiping Linux Malware Deliver Through Malicious Go Modules in Advanced Supply Chain Attack

Cybersecurity researchers have identified multiple malicious packages across Go, npm, and PyPI repositories that threaten Linux systems and developers. Three Go modules—truthfulpharm/prototransform, blankloggia/go-mcp, and steelpoor/tlsproxy—contain obfuscated code targeting Linux. They detect the OS and use wget to download a destructive shell script that overwrites the primary disk (/dev/sda) with zeroes, causing permanent data loss and making the system unbootable.

Several npm packages, including crypto-encrypt-ts, react-native-scrollpageviewtest, and "paypal"-named modules, have been found stealing mnemonic seed phrases, private cryptocurrency keys, and exfiltrating sensitive data. These mainly target cryptocurrency wallets.

On PyPI, seven packages utilise Gmail's SMTP servers and WebSockets to steal data and facilitate remote code execution.

Several npm packages, including crypto-encrypt-ts, react-native-scrollpageviewtest, and "paypal"-named modules, have been found stealing mnemonic seed phrases, private cryptocurrency keys, and exfiltrating sensitive data.

They use hardcoded Gmail credentials to evade detection by exploiting trusted Gmail domains. Other PyPI packages, like web3x and herewalletbot, target crypto wallets by stealing seed phrases.

It is advised to verify auditing dependencies, publishers, monitoring unusual network traffic—especially SMTP—and enforcing strict access controls on private keys.

GhostWeaver Delivered via MintsLoader in Phishing

MintsLoader is a multi-stage malware loader active since early 2023, used to deliver threats such as the PowerShell-based GhostWeaver RAT, according to Orange Cyberdefense. It uses obfuscated JavaScript and PowerShell scripts, incorporating sandbox evasion, virtual machine detection, and a domain generation algorithm (DGA) for HTTP-based C2 communications. MintsLoader is distributed through phishing emails, drive-by downloads, and fake browser update prompts, often targeting industrial, legal, and energy sectors. Threat groups like SocGholish (FakeUpdates) and LandUpdate808 (TAG-124) have weaponised the loader to deliver additional payloads, including StealC and a modified BOINC client. A recent tactic involves ClickFix, a social engineering method that lures users into manually copying and executing malicious JavaScript and PowerShell code from spoofed help sites linked in spam emails. GhostWeaver maintains persistence via encrypted TLS C2 communications using a self-signed X.509 certificate embedded in its script. It generates DGA domains based on the week/year and can deliver plugins for browser data theft and HTML manipulation. GhostWeaver can also deploy MintsLoader as a payload, creating a recursive infection chain.

The proposal builds on Malaysia's role as the first regional coordinator for the ASEAN Regional CERT, which is supported by Singapore with a \$10.1 million budget over ten years to improve incident response and cyber resilience.

Healthcare and Pharma Under Siege: ResolverRAT Delivered via Phishing and DLL Side-Loading

Cybersecurity researchers at Morphisec Labs have discovered ResolverRAT, a sophisticated remote access trojan targeting the healthcare and pharmaceutical sectors. ResolverRAT is delivered via fear-driven phishing emails using legal or copyright-related lures, often localised in languages such as Hindi, Italian, Turkish, and Portuguese to increase infection rates.

The attack chain begins with DLL side-loading, executing an in-memory loader that decrypts the stealthy, encrypted ResolverRAT payload. It uses multiple persistence mechanisms, including Windows Registry entries and redundant file system installations. Communication with the C2 server is secured using custom certificate-based authentication, IP rotation, and certificate pinning, with large exfiltrated data split into small packet size (16 KB chunks) to avoid detection.

The attack chain begins with DLL side-loading, executing an in-memory loader that decrypts the stealthy, encrypted ResolverRAT payload.

Infrastructure overlaps with past Lumma and Rhadamanthys campaigns suggesting possible shared threat actor operations or affiliate models.

Meanwhile, CYFIRMA warns of Neptune RAT, a modular trojan distributed via GitHub, Telegram, and YouTube, offering capabilities like crypto clipping, credential theft, ransomware, MBR overwriting, and live desktop surveillance. It demands \$500 ransom and employs strong anti-analysis features, marking it as a highly dangerous and persistent threat.

The Shadowserver Foundation reported 379 organisations being infected with backdoors that were likely deployed through exploitation of CVE-2025-0282.

Threat Actors Leverage Ivanti ICS Zero-Day (CVE-2025-0282) to Deploy DslogdRAT Malware

A new malware called DslogdRAT has been discovered following the exploitation of CVE-2025-0282, a critical remote code execution flaw in Ivanti Connect Secure (ICS), patched in January 2025. Initially exploited as a zero-day by UNC5337, the vulnerability allowed the deployment of a Perl web shell, which then dropped DslogdRAT and other malware. DslogdRAT connects to an external server to exfiltrate system info, execute shell commands, transfer files, and use the host as a proxy. The Shadowserver Foundation reported 379 organisations being infected with backdoors that were likely deployed through exploitation of CVE-2025-0282.

Attackers Use Cloned Antivirus Website to Deliver Venom RAT and Target Crypto Wallets

The fake antivirus software website shares infrastructure with domains spoofing banks and IT services, including Microsoft and Royal Bank of Canada.

Cybersecurity researchers have uncovered a malicious campaign using a fake website impersonating Bitdefender antivirus software to distribute Venom RAT, a remote access trojan derived from Quasar RAT. The fake site, "bitdefender-download[.]com", lures users to click a "Download for Windows" button, triggering a download from a Bitbucket repository (now inactive) that redirects to an Amazon S3 bucket. The downloaded ZIP file (BitDefender.zip) contains StoreInstaller.exe, which includes Venom RAT, SilentTrinity (a post-exploitation tool), and StormKitty, a stealer targeting credentials and crypto wallets. According to DomainTools Intelligence, the campaign is financially motivated, aiming to steal credentials, access crypto wallets, and sell system access. The fake antivirus software website shares infrastructure with domains spoofing banks and IT services, including Microsoft and Royal Bank of Canada. Venom RAT enables persistent remote access, StormKitty collects sensitive data, and SilentTrinity allows attackers to stay hidden. Meanwhile, Sucuri reported a ClickFix-style campaign using a fake Google Meet page to trick users into running a malicious PowerShell command as a microphone fix. Separately, KnowBe4 exposed phishing via Google's AppSheet, impersonating Meta,

stealing credentials and 2FA codes using AitM pages and polymorphic identifiers to evade detection.

APT41 Leverages Google Calendar for Covert Command-and-Control Communications

Google Threat Intelligence Group (GTIG) identified a malicious campaign involving an exploited government website used to deliver malware named TOUGHPROGRESS. The malware leveraged Google Calendar for command-and-control (C2), allowing it to blend in with legitimate cloud-based activity. The attack began with spear-phishing emails containing a link to a ZIP archive hosted on the compromised government site. The archive contains an LNK file, masquerading as a PDF, and a directory. The malware executes in three stages:

- PLUSDROP: A DLL that decrypts and loads the next stage in memory.
- PLUSINJECT: Uses process hollowing to inject code into a legitimate svchost.exe process.
- TOUGHPROGRESS: Executes actions on the victim's Windows host and communicates via Google Calendar C2.

GTIG developed custom detection fingerprints, took down attacker-controlled Calendars and Google Workspace projects, and updated Safe Browsing blocklists. Working with Mandiant Consulting, GTIG also notified victims and shared TOUGHPROGRESS network logs and threat intelligence to aid detection and response.

Fake Network Tools Used to Spread Chaos RAT Malware on Windows and Linux Systems

Chaos RAT, a cross-platform remote access trojan written in Golang, has re-emerged in attacks targeting both Windows and Linux systems. First observed in malicious use in late 2022, it's now being distributed via phishing emails and disguised as legitimate Linux utilities like "NetworkAnalyzer.tar.gz." The malware supports remote shell access, file operations, system info gathering, screenshots, system control (lock/reboot/shutdown), and URL execution. It establishes persistence on Linux by modifying /etc/crontab to fetch itself periodically. Used alongside XMRig cryptocurrency miners, Chaos RAT is primarily deployed for reconnaissance and lateral movement. The most recent version, v5.0.3, was launched on May 31, 2024. Threat actors continue using it due to its open-source nature and ease of customisation, complicating attribution. Recent variants exploit phishing to target Trust Wallet users on desktops, harvesting browser credentials and clipboard data.

The attack began with spear-phishing emails containing a link to a ZIP archive hosted on the compromised government site.

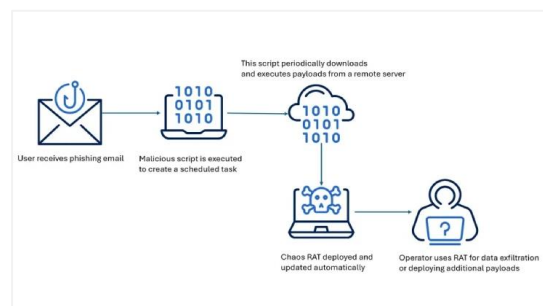


Figure: Malware attack flowchart

The attack begins with users copying an initial PowerShell script, which downloads additional scripts that eventually install NetSupport RAT.

NetSupport RAT Delivered Through Multi-Stage PowerShell Attack

Threat hunters have uncovered a campaign using fake websites mimicking Gitcode and DocuSign to trick users into running malicious PowerShell scripts, infecting machines with NetSupport RAT. According to DomainTools Investigations (DTI), these sites host multi-stage downloader scripts that users are deceived into executing via the Windows Run dialog, often through social engineering on email or social media.

The attack begins with users copying an initial PowerShell script, which downloads additional scripts that eventually install NetSupport RAT. Fake DocuSign sites use ClickFix-style CAPTCHA to trick victims into running obfuscated PowerShell commands copied to their clipboard—a technique called clipboard poisoning. After completing the CAPTCHA, users paste and execute the script, which downloads a persistence payload named wbdims.exe from GitHub, ensuring malware runs on startup. The multi-stage chain downloads a ZIP file containing jp2launcher.exe, which finalises NetSupport RAT deployment. This layered script approach helps evade detection and frustrate takedown efforts. DomainTools linked this campaign to a prior SocGhosh (FakeUpdates) campaign from October 2024 based on similar domains and techniques. While NetSupport Manager is a legitimate administration tool, threat actors like FIN7 and Scarlet Goldfinch often exploit it as a RAT in their attacks

Malicious Browser Extensions Target Chrome and Edge to Steal User Data

Operation Phantom Enigma is a highly sophisticated malware campaign targeting Brazilian users, aiming to steal banking credentials and financial data through malicious browser extensions. Discovered by Positive Technologies, the campaign marks a major shift in banking trojan tactics by exploiting browser extensions to bypass traditional security. The attack begins with phishing emails carrying malicious MSI files disguised as government documents. Once executed, PowerShell scripts create registry entries for persistence, disable User Account Control (UAC), and forcibly install extensions in Chrome, Edge, and Brave by modifying browser policy settings.

The malware checks for Warsaw Technology, a popular Brazilian banking security tool, ensuring it targets only relevant systems. It connects to a command-and-control server at IP 142[.]54[.]185[.]178, using commands like "START_SCREEN" for deploying extensions and "CHECAEXT" to verify installation. Over 70 companies have been affected, with malicious extensions downloaded 722 times from the Chrome Web Store before removal. The malware maintains stealthy, persistent access while evading detection.

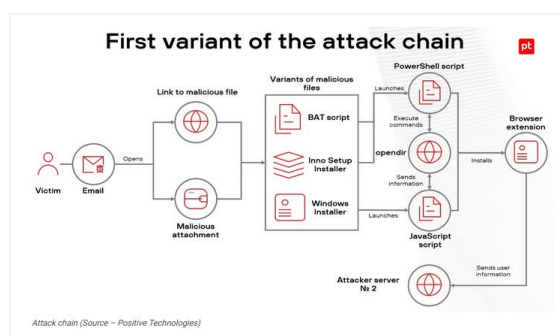


Figure: Attack flowchart

APT37 Group Uses Fake Academic Forum Invites to Spread Harmful LNK Files via Dropbox

APT37 launched Operation ToyBox Story, the campaign uses spear phishing emails impersonating a South Korean national security think tank and referencing a real academic event, enhancing credibility.

APT37 distributes malware via Dropbox links containing compressed archives with malicious LNK shortcut files. These files embed obfuscated PowerShell commands that deploy a multi-stage payload while showing decoy documents to evade detection. The malware reconstructs file extensions at runtime and creates three temporary files: toy01.dat (XOR-encrypted shellcode), toy02.dat (PowerShell script), and toy03.bat (batch file). The shellcode uses XOR with key 0x31 and executes via Windows API calls like GlobalAlloc, VirtualProtect, and CreateThread.

The final payload is RoKRAT malware, which persists through cloud-based command-and-control infrastructure using services like Dropbox, pCloud, and Yandex.

This sophisticated, fileless attack method leverages legitimate cloud services to bypass traditional security, maintain operational security, and complicate attribution and disruption efforts, demonstrating APT37's evolving tactics and deep knowledge of their targets.

The malware reconstructs file extensions at runtime and creates three temporary files: toy01.dat (XOR-encrypted shellcode), toy02.dat (PowerShell script), and toy03.bat (batch file).

Chaos RAT Continues to Evolve, Hits Linux Targets in Fresh Wave of Attacks

The open-source Chaos Remote Administration Tool (RAT) remains active in cyberattacks, with new variants recently identified by the Acronis Threat Research Unit (TRU). Chaos RAT supports Windows and Linux, allowing attackers to execute commands, manage files, and gather system data via a reverse shell. Recent samples suggest increased targeting of Linux systems, with files like NetworkAnalyzer.tar.gz spoofing legitimate utilities. It features a browser-accessible admin panel for payload generation and real-time device control. Once deployed, the RAT collects information such as host name, MAC address, IP, and OS, then adjusts functions accordingly.

The newer variants of Chaos RAT use Base64 encoding, whereas the older versions relied on plain text. Distribution methods include multi-stage loaders and disguised Linux tools. Earlier versions had serious vulnerabilities, including CVE-2024-30850 (command injection) and CVE-2024-31839 (XSS in admin panel), allowing potential hijacking of infected servers.

Acronis also notes other open-source RATs used in campaigns by threat actors: NjRAT (APT41, APT36), QuasarRAT (APT10), Pupy RAT (APT34, APT45), and AsyncRAT (Blind Eagle), highlighting the growing threat from customizable and widely available malware tools.

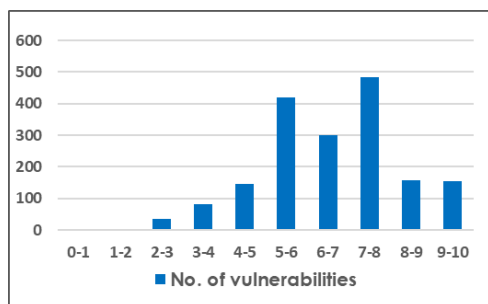
The newer variants of Chaos RAT use Base64 encoding, whereas the older versions relied on plain text. Distribution methods include multi-stage loaders and disguised Linux tools.

Vulnerability Watch

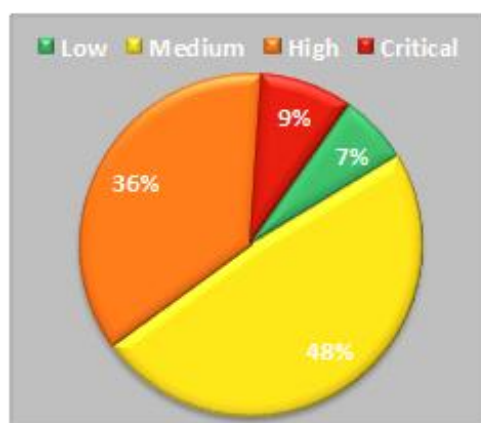
Quarterly Vulnerability Analysis Report

Alert & Advisory Group, NCIIPC

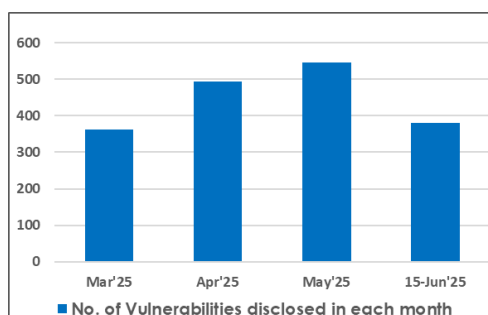
The cyber security trends have suggested surge in critical vulnerabilities & exploits in the quarter impacting widely used software and cloud services. During the second quarter of 2025, a total of 1784 vulnerabilities have been observed. Linux, Adobe, phpgurukul, Qualcomm, and Tenda were the top five vendors having 54% of total reported vulnerabilities. The CVEs have various impact for organisations in critical sectors and require vigilance by relevant SOC/IT teams for patch management & cybersecurity measures.



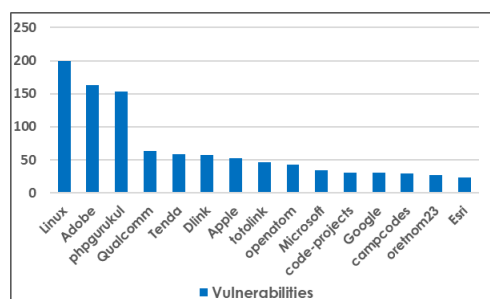
Severity-wise number of vulnerabilities



Severity-wise share of vulnerabilities



No. of vulnerabilities disclosed in each month



Count of vulnerabilities for top 15 vendors

Severity	CVSS v3 Score	Number of Vulnerabilities				Total Vulnerabilities	Severity Total
		Mar	Apr	May	Jun		
Critical	10-9	23	57	59	16	155	155
High	9-8	33	28	53	45	159	643
	8-7	86	143	198	57	484	
Medium	7-6	55	92	75	79	301	867
	6-5	60	116	106	137	419	
	5-4	54	34	41	18	147	
Low	4-3	45	14	9	15	83	119
	3-2	7	11	4	13	35	
	2-1	0	0	1	0	1	
	1-0	0	0	0	0	0	
Total		363	495	546	380		1784

S. No.	Vendor	No. of Vulnerabilities				Total
		Mar'25	Apr'25	May'25	Jun'25	
1.	Linux	29	108	63	0	200
2.	Adobe	0	34	0	129	163
3.	phpgurukul	19	19	65	50	153
4.	Qualcomm	26	0	35	3	64
5.	Tenda	14	12	8	25	59
6.	Dlink	6	8	36	8	58
7.	Apple	19	20	13	0	52
8.	totolink	0	13	20	14	47
9.	openatom	26	0	6	11	43
10.	Microsoft	10	23	0	1	34
11.	code-project	1	15	2	13	31
12.	Google	1	14	11	5	31
13.	campcodes	0	0	21	8	29
14.	Orenom23	2	16	9	0	27
15.	Esri	23	0	0	0	23

Google Chrome Extensions Leak Sensitive Data Over HTTP

Symantec cybersecurity researchers have revealed a troubling flaw in several widely-used Google Chrome extensions, which are leaking sensitive user information due to insecure HTTP connections. The issue arises from extensions transmitting data like browsing activity, machine identifiers, and analytics over plain HTTP instead of the more secure HTTPS protocol. This exposes users to the risk of adversary-in-the-middle (AitM) attacks, especially when using public Wi-Fi networks. In addition to transmitting user data insecurely, some Chrome extensions were found to have hardcoded API keys and secrets embedded in their JavaScript code. These secrets, which included credentials for services like Google Analytics, AWS, and Microsoft Azure, can be exploited by cybercriminals to hijack accounts or inflate service costs. Such vulnerabilities represent a significant risk to both users and developers, potentially allowing malicious actors to access critical systems, replicate financial transactions, or disrupt operations. Researchers urge developers to adopt secure coding practices and avoid transmitting sensitive data over unsecured channels to mitigate these risks.



The issue arises from extensions transmitting data like browsing activity, machine identifiers, and analytics over plain HTTP instead of the more secure HTTPS protocol.

Critical Vulnerability in Commvault Command Center

Critical path traversal vulnerability has been discovered in Commvault's Command Center that allows remote attackers to execute arbitrary code without the need for authentication. Assigned CVE ID CVE-2025-34028 and given a maximum CVSS score of 10.0, this critical vulnerability exposes the Command Center environment to full compromise. By exploiting this flaw, an attacker can gain unauthorised access, potentially compromising sensitive data and disrupting services. The vulnerability was present only in the 11.38 Innovation Release of the Command Center and does not affect later versions. Commvault has issued a fix for this vulnerability in the subsequent Innovation Update releases, which addresses the vulnerability and mitigates the risk of exploitation. NCIIPC has already released alert via advisory: VA-2025-07-07-005.

By exploiting this flaw, an attacker can gain unauthorised access, potentially compromising sensitive data and disrupting services. CVE ID CVE-2025-34028 and CVSS score of 10.0.

Critical Vulnerability in Craft CMS

Critical remote code execution vulnerability was discovered in Craft CMS, a user-friendly CMS for creating custom digital experiences on the web and beyond. Craft is vulnerable to remote code execution. The vulnerability was assigned CVE ID CVE-2025-32432 with CVSS score 10.0. The affected versions are Craft starting from version 3.0.0-RC1 to 3.9.14, 4.0.0-RC1 to 4.14.14, and 5.0.0-RC1 to 5.6.16. Craft has released fixed CMS versions: 3.9.15, 4.14.15 and 5.6.17. NCIIPC has already released alert via advisory: VA-2025-07-07-005.

Craft is vulnerable to remote code execution. The vulnerability was assigned CVE ID CVE-2025-32432 with CVSS score 10.0.



The CVE ID CVE-2025-26389 has CVSS score 10.0 and CVE-2025-26390 has CVSS score 9.8.

Critical Vulnerabilities in Siemens

Critical arbitrary code execution (CVE-2025-26389) and SQL injection (CVE-2025-26390) vulnerabilities have been discovered in Siemens OZW Web Servers. The CVE ID CVE-2025-26389 has CVSS score 10.0 and CVE-2025-26390 has CVSS score 9.8. The affected versions are Siemens OZW672 and OZW772 Web Server. Siemens has released new versions for the affected products and recommends to update to the latest versions. NCIIPC has already released alert via advisory: VA-2025-07-07-005.



The issue stems from the File Picker requesting broad read permissions due to the lack of fine-grained OAuth scopes in OneDrive.

Vulnerability in Microsoft's OneDrive File Picker

Oasis Security's research team has identified a critical vulnerability in Microsoft's OneDrive File Picker. This vulnerability allows websites to access a user's entire OneDrive storage, not just the specific files selected for upload. The issue stems from the File Picker requesting broad read permissions due to the lack of fine-grained OAuth scopes in OneDrive. As a result, applications integrated with OneDrive—such as ChatGPT, Slack, Trello, and ClickUp—are potentially impacted. The OAuth consent screen presented to users is vague, failing to clearly communicate the extent of access being granted. This opens users up to significant security risks, especially when they believe they're only sharing one file but unknowingly authorise access to their full drive. Further compounding the risk, OAuth tokens are often stored insecurely—in plain text within browser session storage—making them vulnerable to exploitation. Microsoft has acknowledged the issue but has yet to release a fix. Until a secure resolution is provided, developers and organisations are advised to consider disabling OneDrive file uploads via OAuth to protect user data from unauthorised access and potential misuse. NCIIPC has already released alert via advisory: VA-2025-07-07-005.



CVE-2025-4427 is an authentication bypass vulnerability having CVSS score 5.3 and CVE-2025-4428 is a remote code execution vulnerability having CVSS score 7.2.

Multiple Vulnerabilities in Ivanti

Ivanti has disclosed two vulnerabilities, CVE-2025-4427 and CVE-2025-4428, that affected Ivanti Endpoint Manager Mobile (EPMM) version 12.5.0.0 and earlier. CVE-2025-4427 is an authentication bypass vulnerability having CVSS score 5.3 and CVE-2025-4428 is a remote code execution vulnerability having CVSS score 7.2. When chained together, these vulnerabilities can allow unauthenticated remote code execution (RCE) on vulnerable systems. Ivanti has released updates for Endpoint Manager Mobile (EPMM). Customers should install one of the fixed versions 11.12.0.5, 12.3.0.2, 12.4.0.2 or 12.5.0.1. NCIIPC has already released alert via advisory: VA-2025-07-07-005.

Critical Vulnerability in Erlang/OTP SSH

A critical vulnerability has been discovered in the Erlang/Open Telecom Platform (OTP) SSH implementation that allow an attacker to perform unauthenticated remote code execution (RCE). The vulnerability allows an attacker with network access to an Erlang/OTP SSH server to execute arbitrary code without prior authentication. This vulnerability has been assigned CVE ID CVE-2025-32433 with an estimated CVSSv3 score of 10.0. Users are advised to update to the latest available Erlang/OTP release. Fixed versions are OTP-27.3.3, OTP-26.2.5.11, and OTP-25.3.2.20. NCIIPC has already released alert via advisory: VA-2025-07-07-005.

This vulnerability has been assigned CVE ID CVE-2025-32433 with an estimated CVSSv3 score of 10.0.

Critical Vulnerability in Cisco

Critical Arbitrary File Upload vulnerability has been discovered in Cisco IOS XE Wireless Controller Software. This vulnerability has been assigned CVE ID CVE-2025-20188 having CVSS score 10.0 and can enable an unauthenticated, remote attacker to upload arbitrary files to a susceptible system. This vulnerability is due to the presence of a hard-coded JSON Web Token (JWT) on an affected system. Cisco has released software updates that address this vulnerability. NCIIPC has already released alert via advisory: VA-2025-05-16-002.

Active Exploitation of CVE-2023-28771 in Zyxel Devices to Launch DDoS Attacks

It has been observed that threat actors have exploited an OS command injection vulnerability in Zyxel networking devices, identified as CVE-2023-28771 having CVSS Score 9.8. This vulnerability enables an unauthenticated remote attacker to execute arbitrary code on the affected device by sending a specially crafted IKEv2 packet to UDP port 500. On successful exploitation of this vulnerability, the attackers compromise the Zyxel devices and incorporate them into a Mirai-based botnet, which is subsequently used to launch Distributed Denial of Service (DDoS) attacks. The Mirai malware targeting these Zyxel firewalls is delivered as a Unix/Linux executable in the linkable executable format (.elf). Zyxel has released patches for this OS command injection vulnerability. Organisations are advised to patch the vulnerable devices on priority basis to avoid exploitation of it. NCIIPC has already released alert via advisory: VA-2025-06-18-013.

It has been observed that threat actors have exploited an OS command injection vulnerability in Zyxel networking devices, identified as CVE-2023-28771 having CVSS Score 9.8.

News Snippets – National

RBI Directs Banks to Migrate to '.bank.in' Domain

On April 22, 2025, the Reserve Bank of India (RBI) directed all commercial banks, urban cooperative banks, state cooperative



भारतीय रिज़र्व बैंक
Reserve Bank of India
India's Central Bank

The introduction of secure domains like '.bank.in' and '.fin.in' aims to curb digital payment fraud and strengthen overall cybersecurity measures.

banks, and district central cooperative banks to begin shifting their digital infrastructure to the new '.bank.in' domain. This directive follows an announcement in the RBI's Statement on Developmental and Regulatory Policies dated February 7, 2025, highlighting the need for enhanced cybersecurity and public trust in digital banking. The introduction of secure domains like '.bank.in' and '.fin.in' aims to curb digital payment fraud and strengthen overall cybersecurity measures. To manage this transition, the Institute for Development and Research in Banking Technology (IDRBT) has been designated the sole registrar for the '.bank.in' domain. This authorisation comes from the National Internet Exchange of India (NIXI), which operates under the Ministry of Electronics and Information Technology (MeitY). Banks must initiate the registration process by contacting IDRBT at sahyog@idrbt.ac.in. The IDRBT will assist throughout the application and migration process. The RBI has set a deadline of October 31, 2025, for completing the migration and urged all banks to act promptly to ensure a secure and seamless digital transition.

The MHA launched e-Zero FIR

The Ministry of Home Affairs' (MHA) Indian Cybercrime Coordination Centre (I4C) has launched the e-Zero initiative to auto-register high-value cybercrimes. This service automates the registration of high-value cybercrimes, specifically those involving financial fraud exceeding Rs 10 lakh. Such crimes, reported through the National Cybercrime Reporting Portal (NCRP) helpline 1930, will now be automatically converted into First Information Reports (FIRs). Initially, the e-Zero initiative has been introduced in Delhi only, but plans are in place to expand it nationwide soon. This move is a strategic step towards enhancing the efficiency of cybercrime investigations. By automating FIR registration, the MHA aims to speed up the legal process, increase the chances of recovering stolen funds, and bolster efforts to tackle cyber fraud.



गृह मंत्रालय
MINISTRY OF
HOME AFFAIRS

Its primary objective is to enhance cybersecurity across the state by providing a comprehensive range of services, including cybersecurity audits, forensic analysis, risk and vulnerability assessments, penetration testing, and incident response.

Maharashtra to Establish Cyber Crime Security Corporation

The Maharashtra government has announced the formation of the Maharashtra Cyber Crime Security Corporation (MCCSC), established under the Companies Act, 2013. The corporation, which will be managed by the state government, will consist of 11 members, led by the additional chief secretary of the state's home department. Its primary objective is to enhance cybersecurity across the state by providing a comprehensive range of services, including cybersecurity audits, forensic analysis, risk and vulnerability assessments, penetration testing, and incident response. The MCCSC will also run statewide awareness campaigns through various media platforms to educate citizens about cybersecurity. It will partner with banks, mobile companies, and financial institutions to strengthen security measures. In

addition, the Corporation will focus on developing research and technology to predict and mitigate cyber threats effectively. By collaborating with both national and international agencies, as well as industry leaders, it aims to build a more secure digital infrastructure. Furthermore, the MCCSC will work closely with law enforcement agencies to combat online piracy, intellectual property theft, and digital fraud.

DoT Introduced 'Financial Fraud Risk Indicator'

The Department of Telecommunications (DoT) has launched the Financial Fraud Risk Indicator (FRI) under the Digital Intelligence Platform (DIP) to strengthen cyber fraud prevention efforts in India. This initiative aims to provide advance actionable intelligence to financial institutions, enabling them to detect and prevent cyber fraud before it occurs. The FRI classifies mobile numbers into three categories—medium, high, and very high risk—based on fraud-related data collected from multiple trusted sources. These include the National Cybercrime Reporting Portal, the DoT's Chakshu platform, and inputs from financial entities. When a digital transaction is initiated, the tool flags high-risk numbers, prompting institutions to apply extra verification checks. The FRI enhances collaboration between the telecom and financial sectors by issuing early fraud warnings. This allows banks and non-banking financial companies (NBFCs) to respond swiftly and improve security protocols for vulnerable customers. Leading UPI platforms such as PhonePe, Paytm, and Google Pay are already integrating DIP alerts into their systems. As UPI dominates India's digital payment space, this initiative could play a critical role in protecting millions from financial cyber fraud.



दूरसंचार विभाग

DEPARTMENT OF TELECOMMUNICATIONS

This initiative aims to provide advance actionable intelligence to financial institutions, enabling them to detect and prevent cyber fraud before it occurs.

News Snippets – International

Nucor Temporarily Halts Production Following Cybersecurity Breach

On May 14, 2025, Nucor Corporation, the U.S.'s leading steel producer, revealed a cybersecurity breach affecting its IT systems. The company, based in Charlotte, took immediate action by shutting down impacted systems and pausing production at various sites to ensure security. Nucor, which operates nearly 300 locations across North America, including steel mills and recycling centers, notified the federal law enforcement authorities and is took the potentially affected systems offline, and also implemented other containment, remediation or recovery measures. The event highlights the increasing vulnerability of critical industries like manufacturing to cyberattacks, emphasising the need for effective cybersecurity strategies.

The company, based in Charlotte, took immediate action by shutting down impacted systems and pausing production at various sites to ensure security.

Cyberattack Disrupted Kettering Health Operations, Patient Care Affected

The ransomware attack had taken down phone lines, the MyChart patient portal and forced the cancellation of elective medical procedures. Emergency departments were diverting ambulances to other hospitals and several systems critical to patient care have been compromised.

Kettering Health was facing a significant technology outage due to a cyberattack by the Interlock ransomware group since May 20, 2025, which disrupted the vital services across its network. The ransomware attack had taken down phone lines, the MyChart patient portal and forced the cancellation of elective medical procedures. Emergency departments were diverting ambulances to other hospitals and several systems critical to patient care have been compromised.

The hospital system confirmed the breach, citing unauthorised access to its network and took immediate steps to contain the threat. While Kettering Health continued to operate emergency services, it has rescheduled all elective procedures for May 20, with plans to provide further updates to patients.

On June 6, 2025, Kettering Health had eradicated Interlock's tools from its systems and conducted a full review of impacted systems. The organisation also said that all updates and patches were in place. As of June 11, 2025, Kettering Health had resumed normal operations for several key services, including hospital-based and outpatient services. MyChart access was also restored, phone lines and call centers were functional across the organisation.

The incident underscores the increasing cybersecurity risks facing healthcare providers, who are prime targets for data theft and disruption due to the valuable nature of patient records.

U.S. Shuts Down DanaBot Malware Network

In a major victory against cybercrime, the U.S. Department of Justice (DoJ) dismantled the DanaBot malware network, responsible for infecting over 300,000 computers globally.

In a major victory against cybercrime, the U.S. Department of Justice (DoJ) dismantled the DanaBot malware network, responsible for infecting over 300,000 computers globally. The malware, linked to a Russia-based cybercriminal group, caused at least \$50 million in damages and facilitated fraud, ransomware and data theft.

The malware operated as a "malware-as-a-service" (MaaS), enabling cybercriminals to steal sensitive data, hijack banking sessions and deliver ransomware. It targeted financial institutions in multiple countries, including the U.S., and was also used for espionage activities.

The operation, part of "Operation Endgame," led to the seizure of DanaBot's command-and-control servers, including those hosted in the U.S. The disruption of the botnet marks a significant blow to a sophisticated criminal network and highlights the importance of international collaboration to combat global cybercrime.

FBI and Europol Disrupt Lumma Stealer Malware Network Linked to 10 Million Infections

In a significant global law enforcement operation, the FBI and Europol, along with cybersecurity partners have dismantled the infrastructure behind Lumma Stealer, one of the world's most notorious malware networks. The operation led to the seizure of over 2,300 domains critical to Lumma's command-and-control system, which had been used to steal sensitive information from millions of victims worldwide.

Active since 2022, Lumma Stealer targeted users by stealing credentials, browser data and cryptocurrency information. The malware-as-a-service (MaaS) model allowed cybercriminals to purchase access to the malware for as low as \$250, with premium packages reaching \$20,000. The malware's reach has been vast, with Microsoft identifying 394,000 infected computers globally between March and May 2025, and a total of 10 million infections attributed to the operation.

While law enforcement actions have disrupted Lumma's activities, experts warn that the actors behind the network will likely adapt and evolve. The takedown emphasises the growing threat of cybercrime and the need for continued collaboration between public and private sectors to combat it effectively.

FBI Warns of AI-Powered Vishing Scams Impersonating Senior US Officials

The FBI has issued a warning about a new AI-driven vishing campaign targeting US federal and state officials. Cybercriminals are using AI-generated voice messages to impersonate senior government figures, as well as the victim's friends and family, to increase the believability of their attacks.

The scammers often send a malicious link after initiating contact, claiming it leads to a different platform. Once on this platform, the attackers can push malware or redirect the victim to a fake site to steal sensitive information, such as login credentials.

Due to advancements in AI, these attacks have become more sophisticated and harder to detect. Vishing—voice phishing—has grown as a tool for social engineering scams, where attackers exploit the trust of their targets.

To stay safe, the FBI advises independently verifying the identity of anyone contacting you, especially via suspicious links or calls, and paying attention to any inconsistencies in voice or tone. Victims should report suspicious activity to the FBI or Internet Crime Complaint Center (www.ic3.gov).

The operation led to the seizure of over 2,300 domains critical to Lumma's command-and-control system, which had been used to steal sensitive information from millions of victims worldwide.

Cybercriminals are using AI-generated voice messages to impersonate senior government figures, as well as the victim's friends and family, to increase the believability of their attacks.

Security App

Quick Heal launches AntiFraud.AI Freemium, Reiterates its Commitment to Cyber Fraud Prevention

Quick Heal Technologies Ltd has unveiled AntiFraud.AI, India's first all-in-one fraud prevention solution, highlighting its dedication to safeguarding users against the escalating threat of cyber fraud. This 'Made in India' solution is designed to offer comprehensive protection against various forms of digital fraud, including phishing, identity theft, and financial scams.

Key Features of AntiFraud.AI:

- **Fraud Call Alert:** Alerts users about calls that may be fraudulent.
- **Scam Protection:** Uses advanced algorithms to detect and prevent access to phishing links and deceptive websites.
- **Banking Fraud Alert:** Utilises AI to detect and alert users to potential banking fraud attempts in real-time.
- **Fraud App Detector:** Constantly monitors for malicious apps and provides instant alerts when potentially dangerous software is detected.
- **Dark Web Monitoring:** Proactively monitors the dark web for exposed sensitive information and promptly notifies users if their data is discovered.
- **Unauthorised Access Alert:** Notifies users if their device's microphone or camera is activated without consent.

These capabilities are further enhanced by the Information Hub, which delivers detailed research and fraud insights from Seqrite Labs, along with the Victim Support feature that offers clear, step-by-step assistance for individuals affected by fraud.

AntiFraud.AI is available on Android, iOS, and Windows platforms, ensuring broad device compatibility.

Microsoft Adds New Agentic AI Tools to Security Copilot

Microsoft has unveiled a significant expansion of its Security Copilot platform, introducing 11 new autonomous AI agents designed to assist organisations in managing the increasing complexity of cybersecurity threats. This enhancement aims to address the growing challenges faced by security teams overwhelmed by the volume and sophistication of cyberattacks.

The newly introduced agents include a Phishing Triage Agent in Microsoft Defender, which filters and prioritises phishing alerts, providing explanations and improving with user feedback. Additionally, the Conditional Access Optimisation Agent monitors identity systems to identify policy gaps and recommend fixes. Another notable addition is the Threat Intelligence Briefing Agent,

Quick Heal Technologies Ltd has unveiled AntiFraud.AI, India's first all-in-one fraud prevention solution, highlighting its dedication to safeguarding users against the escalating threat of cyber fraud.

The newly introduced agents include a Phishing Triage Agent in Microsoft Defender, which filters and prioritises phishing alerts, providing explanations and improving with user feedback.

which curates threat insights tailored to each organisation's risk profile.

Developed both in-house and in collaboration with partners such as OneTrust, Aviatix, and Tanium, these agents are set to begin rolling out in preview starting April 2025. This highlights Microsoft's commitment to leveraging AI to enhance cybersecurity measures and support overburdened security teams in effectively responding to evolving threats.



Google Rolls Out On-Device AI Protections to Detect Scams in Chrome and Android

In a significant move to bolster user security, Google has introduced on-device artificial intelligence (AI) protections to detect and block scams across its platforms, including Chrome and Android. Leveraging its Gemini Nano large language model (LLM), Google aims to provide real-time defences against emerging online threats.

For Chrome users, the integration of Gemini Nano enhances Safe Browsing by analysing web pages locally on the device. This approach allows for the identification of scam indicators, such as deceptive pop-ups or misleading content, even before they are reported to Google's servers. By processing data on-device, the system ensures faster detection and reduces the risk of exposure to new scams.

On Android devices, Google has implemented similar AI-driven features. The Messages app now utilises on-device AI to flag suspicious text messages, alerting users to potential scams. Additionally, Chrome for Android employs machine learning models to detect and warn users about malicious or spammy notifications, providing an extra layer of protection against deceptive practices.

For Chrome users, the integration of Gemini Nano enhances Safe Browsing by analysing web pages locally on the device. This approach allows for the identification of scam indicators, such as deceptive pop-ups or misleading content, even before they are reported to Google's servers.

Google Chrome Can Now Auto-Change Compromised Passwords Using Its Built-In Manager

Google has introduced a major update to Chrome's Password Manager, allowing it to automatically update passwords for accounts that have been compromised. This feature, unveiled at Google I/O 2025, aims to streamline account security by allowing Chrome to detect weak or breached passwords during sign-in and offer users the option to automatically update them with strong, unique replacements.

If a password is found to be compromised on supported sites, Chrome will offer users the ability to automatically resolve the issue. On these sites, Chrome can generate a robust replacement and update the password without requiring manual intervention. This enhancement builds upon Chrome's existing capabilities to



Google has introduced a major update to Chrome's Password Manager, allowing it to automatically update passwords for accounts that have been compromised.

generate strong passwords during sign-up and flag credentials detected in data breaches.

While the feature has not yet been officially launched for end users, it is currently in development. Google is encouraging developers to prepare their websites to support this functionality by implementing specific HTML attributes and URL redirects. Once available, this feature is expected to significantly reduce the friction associated with maintaining secure passwords, helping users protect their accounts with minimal effort.

Learning

Preventive Steps Against Distributed Denial of Service (DDoS)

Alerts & Advisory Group, NCIIPC

A Distributed Denial-of-Service (DDoS) attack occurs when multiple systems flood a targeted server, service, or network with traffic to exhaust resources and render it unavailable to legitimate users. These attacks can cause service outages, financial losses, and reputational damage. The primary targets of DDoS attacks are: Public-facing websites, APIs, DNS servers, email servers, and application platforms

The attack vectors for DDoS attacks are:

- Volumetric Attacks: Flooding bandwidth (e.g., UDP floods, ICMP floods)
- Protocol Attacks: Exploiting server resources (e.g., SYN floods, Ping of Death)
- Application Layer Attacks: Targeting specific apps or services (e.g., HTTP floods, slow POSTs)

Below given are some indicators of a DDoS attacks:

- Unusually slow network performance
- Website/application unavailability
- Spikes in traffic from a single IP range or geographic region
- Inability to access systems remotely
- Server crash or downtime alerts

Recommended mitigation steps for DDoS attack are given below:

Mitigation Steps for Application Layer Attacks:

- The centralised Web Application Firewall (WAF) may be configured with both Transactions Per Second (TPS) based and Behaviour based L7 DDoS Protection. The requests are blocked in case the attack is detected. This configuration covers source IP, device ID and Geolocation based thresholds.
- The prevention against application-layer DDOS attacks is through holistic defences that combine web application firewalls, bot mitigation, API security and DDoS protection.

Mitigation Steps for Protocol Attacks:

- Define strict "TCP keepalive" and "maximum connection" on all perimeter devices, such as firewalls and proxy servers. This

Regulated entities must conduct thorough risk analyses and implement appropriate security measures based on their size and specific risks.

The centralised Web Application Firewall (WAF) may be configured with both Transactions Per Second (TPS) based and Behaviour based L7 DDoS Protection. The requests are blocked in case the attack is detected.

recommendation assists with keeping SYN Flood attacks from being successful.

- To minimise the effect of UDP Flood attacks, define strict rules on network devices, to allow only inbound traffic on ports that are required.
- To mitigate some of the damage of ICMP Flood attacks, restrict ICMP traffic at perimeter network devices.

Mitigation Steps for Volumetric Attacks:

- Consider port and packet size filtering by the upstream network service provider.
- The rate limit for application DDoS protection at SSL Layer should be enabled for specific IPs using challenge response mechanisms beyond configured threshold in on premises Anti-DDoS solution. Configure firewalls to block, as a minimum, inbound traffic sourced from IP addresses that are reserved (0/8), loopback (127/8), private (RFC 1918 blocks 10/8, 172.16/12, and 192.168/16), unassigned DHCP clients (169.254.0.0/16), multicast (224.0.0.0/4) and otherwise listed in RFC 5735. This configuration should also be requested at the ISP level.

Mitigation Steps for Service / ISP level DDoS Protection:

- DDoS Scrubbing Services from Internet Service Providers may be considered.
- DDoS mitigation should be invoked at ISP level whenever threshold is breached for the class of traffic and respective alert should be generated. Establish and maintain effective partnerships with upstream network service provider and know what assistance they may be able to provide in the event of a DDoS attack. In the case of a DDoS attack, the faster a provider can implement traffic blocks and mitigation strategies at their level, the sooner services will become available for legitimate users.

Mitigation Steps for Network Monitoring:

- Enable firewall logging of accepted and denied traffic to determine where the DDoS may be originating.
- Establish and regularly validate baseline traffic patterns (volume and type) for public-facing websites.
- Manage app and API security in one place, relying on multiple integrated solutions to mitigate application-layer attacks seamlessly while preventing workflow disruptions.
- Continuously monitor the network activities; server logs to detect and mitigate suspicious and malicious activities in your network. Review the traffic patterns and logs of perimeter devices to detect anomalies in traffic, network level floods (TCP, UDP, SYN, etc.) and application floods (HTTP GET) etc.
- Implement Egress and Ingress filtering at router level. Ensure that Intrusion/DDoS Prevention System contain signatures to detect the attacks launched from common DDoS tools.
- Implement a bogon block list at the network boundary. Identify the attack sources.

The rate limit for application DDoS protection at SSL Layer should be enabled for specific IPs using challenge response mechanisms beyond configured threshold in on premises Anti-DDoS solution.

Implement Egress and Ingress filtering at router level. Ensure that Intrusion/DDoS Prevention System contain signatures to detect the attacks launched from common DDoS tools.

- Block the attack sources at Router/Packet filtering device/DDoS prevention solutions. Disable non-essential ports/services.
- Segment networks into smaller networks to limit the impact of DoS attack. This can be done by creating VLANs.

Fast Flux: A National Security Threat

The U.S. Cybersecurity and Infrastructure Security Agency (CISA), along with the NSA and FBI, has issued a warning about the growing national security risks posed by a cyber technique known as fast flux. The fast flux method is used by cybercriminals and state-backed hackers to hide their malicious online infrastructure. It works by quickly switching DNS records—such as IP addresses and name servers—linked to a single domain, making it difficult for defenders to block or trace. There are two forms of fast flux: single flux, which changes IP addresses rapidly, and double flux, which also rotates the name servers that manage those addresses. This added complexity helps attackers maintain their operations despite defensive efforts. The technique has been linked to phishing, malware delivery, and other cyberattacks, including campaigns by known threat groups like Gamaredon.

To combat fast flux, the advisory suggests organisations implement layered defences. These include monitoring DNS activity for unusual changes, analysing network traffic, sharing threat data with partners, and restricting access to suspicious domains. As cyber threats become more advanced, proactive detection and collaboration are key to reducing the risks posed by fast flux tactics.

AI Data Security

The U.S. Cybersecurity and Infrastructure Security Agency (CISA), working with the NSA, FBI, and international partners, has published guidance on protecting data used in artificial intelligence systems. Titled “AI Data Security: Best Practices for Securing Data Used to Train & Operate AI Systems,” the document outlines measures to ensure the safety and reliability of data throughout the development and deployment of AI technologies.

The guidance highlights the importance of securing data against unauthorised access, tampering, or misuse, as such threats can undermine the performance and trustworthiness of AI systems. Recommended actions include using encryption, applying digital signatures, controlling access to sensitive datasets, and maintaining detailed records of data origin and changes to ensure authenticity.

Several risk areas are identified, including vulnerabilities in data supply chains, the danger of manipulated or poisoned data during

The fast flux method is used by cybercriminals and state-backed hackers to hide their malicious online infrastructure.

The guidance highlights the importance of securing data against unauthorised access, tampering, or misuse, as such threats can undermine the performance and trustworthiness of AI systems.

training, and changes in data patterns over time that could impact performance. As AI tools become increasingly integrated into critical sectors, safeguarding data has become essential. This advisory encourages organisations to adopt robust security practices to protect their AI systems from emerging cyber threats and ensure operational reliability.

NIST Introduced New Metric to Measure Likelihood of Vulnerability Exploits

The National Institute of Standards and Technology (NIST) has introduced a new metric called Likely Exploited Vulnerabilities (LEV) to help cybersecurity teams better understand which software vulnerabilities have been exploited. The LEV calculation guides prioritisation efforts and builds upon the existing Exploit Prediction Scoring System (EPSS). When using LEV, vulnerability managers would receive the following data:

- CVE name, publish date and description
- LEV probability (i.e. the probability of past observation of exploitation)
- The peak (i.e. maximum) EPSS score among the evaluated 30 day windows
- The date of the peak EPSS score
- The EPSS scores for each of the 30-day windows
- The dates for each window
- The affected products using Common Platform Enumeration (CPE) values

LEV can also be used in conjunction with EPSS and the Known Exploited Vulnerability (KEV) lists.

The Seven Pillars of Cyber-Resilience

Kaspersky outlines seven foundational elements that help organisations strengthen their ability to manage and recover from cyber threats.

- **Leadership:** Cyber-resilience must be a core part of business strategy. Leaders should communicate its value clearly, define acceptable risk thresholds, and empower teams to act swiftly during cyber incidents.
- **Governance, Risk, and Compliance:** Organisations should identify their cyber risk profile, assign accountability for each risk area, implement targeted risk-reduction strategies, and ensure full compliance with relevant regulations.
- **People and Culture:** Building a strong cybersecurity culture involves training staff based on their specific roles, recruiting individuals with essential skills, and fostering an environment where employees can report issues without fear.
- **Business Processes:** Key IT services should be ranked by their role in continuity. Companies must prepare for worst-case

The LEV calculation guides prioritisation efforts and builds upon the existing Exploit Prediction Scoring System (EPSS).

Cyber-resilience must be a core part of business strategy. Leaders should communicate its value clearly, define acceptable risk thresholds, and empower teams to act swiftly during cyber incidents.

Critical systems require strong, tailored protections—such as secure configurations, MFA, backups, and network segmentation. Monitoring and response tools like XDR or SIEM+SOAR are vital.

Accounts that remain inactive for long periods, known as dormant accounts, create significant security risks for organisations. Because these accounts often miss regular updates like strong passwords or multi-factor authentication, they become easy targets for hackers looking to gain unauthorised access.

scenarios by planning how essential operations can continue during major system outages.

- **Technical Systems:** Critical systems require strong, tailored protections—such as secure configurations, MFA, backups, and network segmentation. Monitoring and response tools like XDR or SIEM+SOAR are vital.
- **Crisis Management:** Effective response plans, designated leaders, and backup communication channels are crucial for managing and recovering from incidents.
- **Ecosystem Engagement:** Strengthen resilience by collaborating with partners, regulators, and industry peers.

Together, these seven components form a well-rounded approach to cyber-resilience, ensuring businesses can prepare for, survive, and adapt to cybersecurity challenges while continuing essential operations.

Dormant Accounts Become a Doorway for Cybercriminals

Accounts that remain inactive for long periods, known as dormant accounts, create significant security risks for organisations. Because these accounts often miss regular updates like strong passwords or multi-factor authentication, they become easy targets for hackers looking to gain unauthorised access. Another concern is that many users reuse passwords across multiple platforms, meaning a breach in one account can lead to further compromises elsewhere. Moreover, dormant accounts typically receive little to no monitoring, allowing cybercriminals to operate unnoticed for extended periods.

To address these vulnerabilities, organisations should perform routine reviews to identify and deactivate inactive accounts. Adding multi-factor authentication strengthens security by requiring additional verification steps beyond just passwords. It's also important to enforce password policies that demand unique, complex credentials for every account. Additionally, educating employees on the dangers linked to dormant accounts and encouraging best practices in account management helps reduce risks.

By managing dormant accounts proactively, organisations can prevent these overlooked entry points from being exploited, thereby improving their overall cybersecurity defences and safeguarding critical data.

Cyber Security Issues in Auto Transport: Understanding Risks and Threats

The auto transport sector is facing growing cybersecurity challenges as vehicles and related systems become more connected and reliant on technology. This increased connectivity exposes the transport industry to new risks, including unauthorised access to sensitive customer data and potential security breaches

caused by user errors in complex software platforms. Cybercriminals can exploit these vulnerabilities due to the expanded number of access points created by interconnected systems.

Sharing personal and financial information among multiple service providers also raises concerns about data privacy and protection. These issues have contributed to a sharp rise in cyber incidents, with the industry seeing a significant increase in attacks over recent years.

To address these threats, companies in the auto transport space should regularly review and assess their security measures to identify weaknesses. Strengthening cybersecurity protocols and adopting comprehensive protection strategies are critical to defend against sophisticated cyberattacks. By taking proactive steps, organisations can better safeguard their systems, protect customer information, and maintain trust in an increasingly digital environment.

'SIEM Sprawl' Makes It Tough for Security Teams to Detect What Matters

The 2025 CardinalOps report reveals that many organisations face difficulties maximising the effectiveness of their Security Information and Event Management (SIEM) systems. Despite substantial investments, only about one-third of relevant cyber threats are detected, showing little improvement over time. A major problem is that a significant portion of detection rules—nearly 28%—are either inactive or malfunctioning, causing wasted effort and resources. Furthermore, very few detection rules are tailored to the specific needs of individual organisations, which reduces their accuracy and relevance. Most detection relies heavily on endpoint and authentication logs, leaving other important data sources underutilised.

To address these shortcomings, organisations are adopting new approaches such as combining SIEM with Extended Detection and Response (XDR) platforms to expand coverage. Shifting towards data lake infrastructures allows better handling of large volumes of security data. Artificial intelligence and machine learning are increasingly used to refine and automate detection rules, eliminating redundancies. Additionally, adopting Detection-as-Code (DaC) practices helps automate rule management, enabling security teams to respond more effectively to emerging threats.

To address these threats, companies in the auto transport space should regularly review and assess their security measures to identify weaknesses.

Furthermore, very few detection rules are tailored to the specific needs of individual organisations, which reduces their accuracy and relevance. Most detection relies heavily on endpoint and authentication logs, leaving other important data sources underutilised.

Mobile Security

Crocodilus Android Malware Expands Globally, Targets Banks and Crypto Wallets

A new Android banking trojan called Crocodilus is rapidly evolving, targeting users in Europe, South America, India, Indonesia, and the U.S., according to a ThreatFabric report. It initially affected Spain and Turkey in March 2025 by masquerading as apps like Google Chrome. Crocodilus performs overlay attacks to steal banking credentials and abuses accessibility services to extract cryptocurrency wallet seed phrases. It applies various obfuscation techniques to impede detection and make reverse engineering challenging. New capabilities include adding fake contacts (e.g., "Bank Support") using a command (TRU9MMRHBCRO)—likely to bypass Google's anti-scam alerts during screen sharing. It also features an automated parser to extract crypto wallet seed phrases and private keys.

The malware spreads via fake ads on Facebook, fraudulent browser updates, or casino apps, redirecting victims to malicious download sites. ThreatFabric warns Crocodilus is no longer regionally limited, indicating active development and global expansion. Google confirms no infected apps are on the Play Store, and Play Protect can block harmful apps even if installed from outside sources.

Triada Malware Resurfaces on Counterfeit Android Phones, Infects Thousands

A new wave of infections tied to the well-known Triada malware has surfaced, this time hiding in counterfeit Android phones which are being sold at unusually low prices. According to a recent report by Kaspersky, more than 2,600 devices were compromised. Triada is a sophisticated Android backdoor that gives attackers complete remote access to the device. What makes this latest version especially dangerous is that it comes preloaded into the phone's firmware—not downloaded later through shady apps—making it almost impossible to remove without reinstalling the system software.

Once active, Triada can steal account credentials from instant messengers and social networking apps, intercept and alter messages, hijack cryptocurrency wallet addresses from clipboard content, monitor web browser and call activity, download additional malware etc.

Kaspersky points to supply chain breaches as the cause, where outside vendors sneak the malware into devices while they're being made. Google confirmed the affected phones are not Play Protect certified and do not meet Android security standards. Researchers warn Triada remains one of the most complex and dangerous Android threats to date, with attackers reportedly stealing over \$270,000 in crypto assets through this campaign.

Crocodilus performs overlay attacks to steal banking credentials and abuses accessibility services to extract cryptocurrency wallet seed phrases. It applies various obfuscation techniques to impede detection and make reverse engineering challenging.

Once active, Triada can steal account credentials from instant messengers and social networking apps, intercept and alter messages, hijack cryptocurrency wallet addresses from clipboard content, monitor web browser and call activity, download additional malware etc.

Android and iOS Under Siege: Spyware Campaigns Exploit Fake App Downloads

Cybersecurity experts have recently noticed a new surge in attacks targeting Android users. Hackers are setting up fake websites that look just like the Google Play Store, tricking people into downloading harmful apps that pretend to be popular ones, like Chrome. The teams at DomainTools Investigations (DTI) found that these fake sites are in both English and Chinese. Once installed, SpyNote takes advantage of Android's accessibility features to quietly steal personal info like messages, contacts, call logs, and location. It can even take control of phone's camera and microphone remotely. SpyNote, sometimes called SpyMax, has been around for years and is connected to other malware like Gigabud and BadBazaar. Some of these threats are believed to come from a Chinese hacking group known as GoldFactory, and state-backed actors like OilAlpha have also used SpyNote in the past. Experts are also warning about spyware called BadBazaar and MOONSHINE, which is targeting Uyghur, Tibetan, and Taiwanese communities. These apps pretend to be normal messaging or utility tools but steal personal data from Android and iPhone users secretly. To stay safe, only download apps from official stores and use devices that have Google Play Protect certification.

Once installed, SpyNote takes advantage of Android's accessibility features to quietly steal personal info like messages, contacts, call logs, and location. It can even take control of phone's camera and microphone remotely.

SuperCard X Malware Hijacks Contactless Payments via NFC

SuperCard X malware was first spotted in Italy. It's a tool that scammers use to steal card information when a victim taps their card on their phone. The stolen data is then used to withdraw money or make purchases using a cloned version of the card.

How the Scam Works:

- Smishing: Victims might receive SMS or WhatsApp message claiming there's suspicious activity on their bank account. It urges them to call a number, where fake "bank staff" talk to the victim.
- Convincing Phone Calls: Scammers then persuade the victim to:
 - Share their card PIN
 - Disable any security limits
 - Install an app that looks legitimate—but is actually the SuperCard X malware
- Card Cloning via NFC: Once the app is installed, it activates when the victim taps their card. It captures the card data and sends it to the scammer via HTTP/mTLS. The attacker then clones the card to steal money.

It's a tool that scammers use to steal card information when a victim taps their card on their phone. The stolen data is then used to withdraw money or make purchases using a cloned version of the card.

Safety Measures:

- Ignore unexpected "bank" messages
- Never install apps suggested during a call
- Review installed apps and delete anything with NFC access you don't recognise

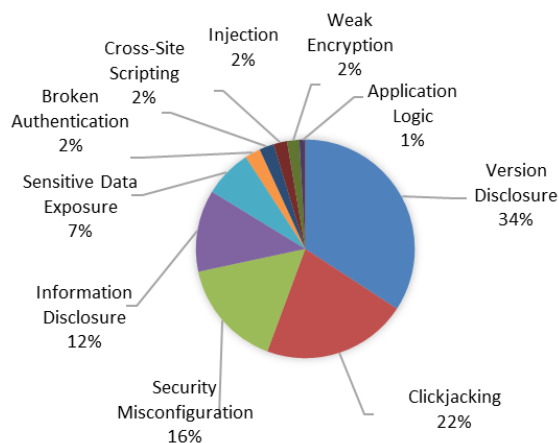
NCIIPC Initiatives



NCIIPC Responsible Vulnerability Disclosure Program (RVDP)

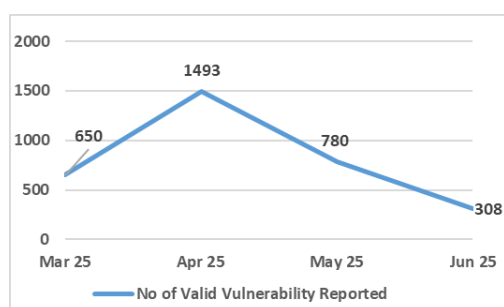
The NCIIPC Responsible Vulnerability Disclosure Program provides opportunity for researchers to disclose vulnerability observed in Nation's Critical Information Infrastructure. There are 3231 vulnerabilities reported during the second quarter of 2025. The top 10 vulnerabilities are:

- Version Disclosure
- Clickjacking
- Security Misconfiguration
- Information Disclosure
- Sensitive Data Exposure
- Broken Authentication
- Cross-Site Scripting
- Injection
- Weak Encryption
- Application Logic



Around 403 security researchers participated in RVDP programme during the second quarter of 2025. NCIIPC acknowledges following top 15 researchers for their contributions (names are in alphabetical order):

- Abhay A L
- Ashutosh Kumar
- Gopal Waddar
- Prasad R Sonar
- Prashanth Kumar Konda
- Rajesh Bhandekar
- Rohit Raj
- Ronak Kumar
- Sardhara Sakshi Amit
- Shailesh kumar
- Smeet Almeida
- Sravanthi Pachunoori
- Subhash Kumawat
- Tushar
- Yash



Last three months' timeline chart for vulnerabilities reported

NCIIPC Startup India AI Grand Challenge

NCIIPC has launched Startup India AI Grand Challenge on 1st July 2025. The NCIIPC Startup India AI Grand Challenge is a pioneering initiative to encourage Deep Tech Startups to build indigenous Products/Solutions to the Challenges in the National Security domain. Indian Startups and Student Groups working in the field of Artificial Intelligence are invited to join this challenge to provide innovative solutions for various problem statement. The challenge has 12 Problem Statements (PS), each posing a unique challenge to the Indian Deep Tech Talent to come up with innovative solutions to strengthen National Security Apparatus. The AI Grand Challenge will unfold in 3 main stages over 14 months period, from 11 August 2025 to 30 September 2026. Winning Teams with promising solutions will be eligible for a post-challenge contract on nomination basis. Additional information about AI Grand Challenge is available on <https://ai-grand-challenge.in>.



NCIIPC Organised 3rd Edition of CII-SECEX 2025

The third edition of the national level Critical Information Infrastructure Security Exercise (CII-SECEX 2025) was conducted by NCIIPC from 11th to 20th April 2025. The exercise was attended by approximately 1000 officials from various CII Organisations/Ministries at Delhi, Mumbai, Bengaluru and Kolkata. The event was inaugurated by Dy. NSA Sh. T.V. Ravichandran on 11th April 2025. The event comprised four distinct segments as given below:

- Cyber Security Training and Operational Exercise: This program was of 06 days (11-16 April 2025), hands on training followed by three days (18-20 April 2025) hands on operational exercise were held simultaneously at 4 locations across the country viz. Delhi, Mumbai, Bengaluru & Kolkata.
- Advanced Operational Exercise: This year NCIIPC introduced two parallel advanced level operational exercises on IT and SOC themes.
- Strategic Exercise: A 2-day long exercise based on the Cyber Security Capability Maturity (CSCM) model for Senior Management level officials of Critical Sector Entities dealing with Cyber Security related issues and policies was held during 19-20 April 2025 at Bharat Mandapam, New Delhi.
- CEO Level Exercise: A half day exclusive CEO level exercise was held in Delhi on 20th April at Bharat Mandapam, New Delhi. Theme of this exercise was "Indian Cybersecurity Stack 2030: NCRF, a Start Point".

The event concluded on 20th April 2025 with a valedictory address by Sh. S. Krishnan, Secretary, Ministry of Electronics and Information Technology. The top-performing teams were acknowledged and awarded.



*Dy. NSA, Sh. T.V. Ravichandran & DG NCIIPC,
Sh. Navin Kumar Singh at inauguration of
CIISECEX 2025*



JULY 2025

S	M	T	W	T	F	S
		1	2	3	4	5
6	7	8	9	10	11	12
13	14	15	16	17	18	19
20	21	22	23	24	25	26
27	28	29	30	31		

AUGUST 2025

S	M	T	W	T	F	S
31					1	2
3	4	5	6	7	8	9
10	11	12	13	14	15	16
17	18	19	20	21	22	23
24	25	26	27	28	29	30



Events - India

- BSides Bangalore, Bengaluru 11 Jul
- BSides Mumbai, Mumbai 12 Jul
- Namma Privacy 2025, Bengaluru 17 Jul
- Open Source Summit, Hyderabad 5 Aug
- c0c0n, Kochi 7-11 Oct

Events - Global

July 2025

- CYDES 2025, Putrajaya 1-3 Jul
- Cyber Security Training at SANSFIRE, Washington & Virtual 14-19 Jul
- DC Metro Cybersecurity Summit, McLean 17 Jul
- DeepLearn 2025, Porto-Maia 21-25 Jul
- PhilSec, Philippines 22-23 Jul
- SANS 2025 Government Security Forum, Virtual 22 Jul
- INTERFACE Montana 2025, Montana 30 Jul

August 2025

- Black Hat USA, Las Vegas 2-7 Aug
- USENIX Security Symposium, Seattle 13-15 Aug
- BFSI IT Summit, Singapore 14 Aug
- Detroit Cybersecurity Summit, Detroit 19 Aug
- SANS 2025 Cloud Security Exchange, Virtual 21 Aug
- Generative AI Summit, Los Angeles 27 Aug
- Interface Boise, Boise 28 Aug
- LinuxSecuritySummit, Amsterdam 28-29 Aug

September 2025

- Netskope SASE Summit, Sao Paulo 9 Sep
- ClOMeet, Chicago 9 Sep
- Chief AI Officer Summit, Berlin 11 Sep
- Security BSides Kraków, Kraków 27 Sep
- MLCon Conference & Training, New York 29 Sep-3 Oct
- Cyberweek Africa 2025, Nairobi 29 Sep-3 Oct
- CIVO Navigation, London 30 Sep
- Columbus Cybersecurity Summit, Columbus 30 Sep

SEPTEMBER 2025

S	M	T	W	T	F	S
	1	2	3	4	5	6
7	8	9	10	11	12	13
14	15	16	17	18	19	20
21	22	23	24	25	26	27
28	29	30				

October 2025

- CDAO Malaysia, Kuala Lumpur 7 Oct
- CyberBay 2025, Tampa 13-15 Oct
- ManuSec, Illinois 14-15 Oct
- Industrial Control Systems Cybersecurity Conference, Atlanta 27-30 Oct
- Unhacked Cybersecurity Conference, Prague 27-29 Oct
- Red Hat Summit, Seoul 28 Oct
- SecureWorld, New York 29 Oct

OCTOBER 2025

S	M	T	W	T	F	S
			1	2	3	4
5	6	7	8	9	10	11
12	13	14	15	16	17	18
19	20	21	22	23	24	25
26	27	28	29	30	31	

**General Help**

helpdesk1@nciipc.gov.in
helpdesk2@nciipc.gov.in

Incident Reporting

: ir@nciipc.gov.in

Vulnerability Disclosure

: rvd@nciipc.gov.in

Malware Upload

: mal.repository@nciipc.gov.in

Abbreviations

- **ACD:** Active Cyber Defense
- **C2:** Command-and-Control
- **CISA:** Cybersecurity and Infrastructure Security Agency
- **DaC:** Detection-as-Code
- **DDoS:** Distributed Denial of Service
- **DGA:** Domain Generation Algorithm
- **DIP:** Digital Intelligence Platform
- **DOJ:** Department of Justice
- **DoT:** Department of Telecommunications
- **DTI:** DomainTools Investigations
- **EPSS:** Exploit Prediction Scoring System
- **FRI:** Fraud Risk Indicator
- **GTIG:** Google Threat Intelligence Group
- **IC3:** Internet Crime Complaint Center
- **ICS:** Ivanti Connect Secure
- **IDRBT:** Institute for Development and Research in Banking Technology
- **LEV:** Likely Exploited Vulnerabilities
- **LLM:** Large Language Model
- **MaaS:** Malware-as-a-Service
- **MCCSC:** Maharashtra Cyber Crime Security Corporation
- **MeitY:** Ministry of Electronics and Information Technology
- **NBFC:** Non-Banking Financial Company
- **NCRP:** National Cybercrime Reporting Portal
- **NIST:** National Institute of Standards and Technology
- **NIXI:** National Internet Exchange of India
- **OTP:** Open Telecom Platform
- **PS:** Problem Statements
- **RAT:** Remote Administration Tool
- **RBI:** Reserve Bank of India
- **RCE:** Remote Code Execution
- **SIEM:** Security Information and Event Management
- **TPS:** Transactions Per Second
- **TRU:** Threat Research Unit
- **UAC:** User Account Control
- **WAF:** Web Application Firewall
- **XDR:** Extended Detection and Response

Sources

- **Japanese Parliament Passes Active Cyber Defense Law**
<https://www.bankinfosecurity.com/>
- **Deepfake Deception: The New Frontier of Social Engineering Cybercrime**
<https://www.lumifycyber.com/>
- **Microsoft Launches Free EU Cybersecurity Program to Counter State-Sponsored Threats**
<https://blogs.microsoft.com/>
<https://www.bleepingcomputer.com/>
- **Disk-Wiping Linux Malware Delivered Through Malicious Go Modules in Advanced Supply Chain Attack**
<https://socket.dev/>
- **GhostWeaver Delivered via MintsLoader in Phishing**
<https://www.recordedfuture.com/>
- **Healthcare and Pharma Under Siege: ResolverRAT Delivered via Phishing and DLL Side-Loading**
<https://www.cyfirma.com/>
<https://www.aumint.io/>
- **Threat Actor Deploys CurlBack and Spark RATs Against Indian Critical Sectors**
<https://www.seqrte.com/>
- **Threat Actors Leverage Ivanti ICS Zero-Day (CVE-2025-0282) to Deploy DslogdRAT Malware**
<https://forums.ivanti.com/>
- **Attackers Use Cloned Antivirus Website to Deliver Venom RAT and Target Crypto Wallets**
<https://dti.domaintools.com/venomrat/>
- **APT41 Leverages Google Calendar for Covert Command-and-Control Communications**
<https://cloud.google.com/>
<https://workspace.google.com/>
- **Fake Network Tools Used to Spread Chaos RAT Malware on Windows and Linux Systems**
<https://www.blackhatethicalhacking.com>
- **NetSupport RAT Delivered Through Multi-Stage PowerShell Attack**
<https://dti.domaintools.com/how-threat-actors-exploit-human-trust/>
- **Malicious Browser Extensions Target Chrome and Edge to Steal User Data**
<https://cybersecuritynews.com/>
- **APT37 Group Uses Fake Academic Forum Invites to Spread Harmful LNK Files via Dropbox**
<https://cybersecuritynews.com/>
- **Chaos RAT Continues to Evolve, Hits Linux Targets in Fresh Wave of Attacks**
<https://www.scworld.com/>
- **Google Chrome Extensions Leak Sensitive Data Over HTTP**
<https://cybersrcc.com/>
<https://chromereleases.googleblog.com/>

- **Critical Vulnerability in Commvault Command Center**
<https://documentation.commvault.com/>
- **Critical Vulnerability in Craft CMS**
<https://nvd.nist.gov/vuln/detail/CVE-2025-32432>
<https://sensepost.com/>
- **Critical Vulnerabilities in Siemens**
<https://cert-portal.siemens.com/productcert/html/ssa-047424.html>
- **Vulnerability in Microsoft's OneDrive File Picker**
<https://thehackernews.com/>
<https://www.microsoft.com/en-in/>
- **Multiple Vulnerabilities in Ivanti**
<https://www.fortiguard.com/>
- **Critical Vulnerability in Erlang/OTP SSH**
<https://www.openwall.com/>
<https://thehackernews.com/>
- **Critical Vulnerability in Cisco**
<https://sec.cloudapps.cisco.com/>
<https://thehackernews.com/>
- **Active Exploitation of CVE-2023-28771 in Zyxel Devices to Launch DDoS Attacks**
<https://www.zyxel.com/>
CERT-IN [CMTX-P062025776]
- **RBI Directs Banks to Migrate to '.bank.in' Domain**
<https://www.pdicai.org/>
- **The MHA launched e-Zero FIR**
<https://timesofindia.indiatimes.com/>
<https://xn--i1b5bzbybhfo5c8b4bxh.xn--11b7cb3a6a.xn--h2brj9c/en>
- **Maharashtra to Establish Cyber Crime Security Corporation**
<https://ciso.economictimes.indiatimes.com/>
<https://cdnbbsr.s3waas.gov.in/>
- **DoT Introduced 'Financial Fraud Risk Indicator'**
<https://www.pib.gov.in/>
<https://dot.gov.in/>
- **Nucor Temporarily Halts Production Following Cybersecurity Breach**
<https://www.secureworld.io/>
- **Cyberattack Disrupted Kettering Health Operations, Patient Care Affected**
<https://www.daytondailynews.com/>
<https://www.techtarget.com/>
- **FBI and Europol Disrupt Lumma Stealer Malware Network Linked to 10 Million Infections**
<https://blogs.microsoft.com/>
<https://therecord.media/lumma-infostealer-malware-takedown-microsoft-fbi>
- **FBI Warns of AI-Powered Vishing Scams Impersonating Senior US Officials**
<https://www.malwarebytes.com/>

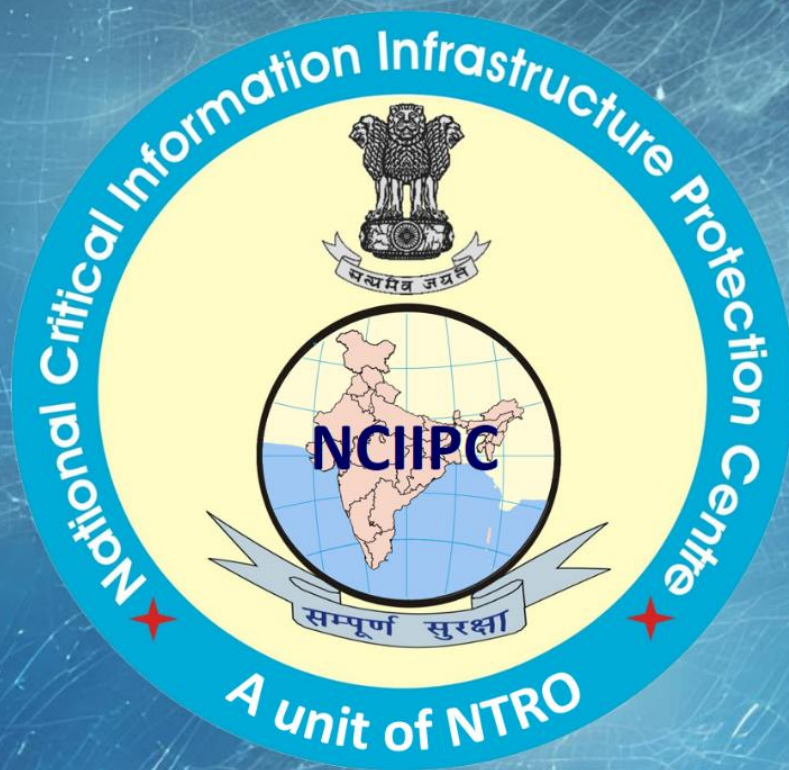
- **Quick Heal launches AntiFraud.AI Freemium, Reiterates its Commitment to Cyber Fraud Prevention**
<https://www.expresscomputer.in/>
<https://www.thehindubusinessline.com/>
- **Microsoft Adds New Agentic AI Tools to Security Copilot**
<https://enablement.microsoft.com/>
<https://www.theverge.com/>
<https://copilot.microsoft.com/>
- **Google Rolls Out On-Device AI Protections to Detect Scams in Chrome and Android**
<https://www.androidcentral.com/>
<https://www.lifewire.com/>
<https://blog.google/>
- **Google Chrome Can Now Auto-Change Compromised Passwords Using Its Built-In Manager**
<https://www.lifewire.com/>
<https://www.theverge.com/>
- **Fast Flux: A National Security Threat**
<https://media.defense.gov/>
- **AI Data Security**
<https://media.defense.gov/>
- **NIST Introduced New Metric to Measure Likelihood of Vulnerability Exploits**
<https://www.infosecurity-magazine.com/>
- **The Seven Pillars of Cyber-Resilience**
<https://www.kaspersky.com/blog/cyber-resilience-101/53464/>
- **Dormant Accounts Become a Doorway for Cybercriminals**
<https://www.welivesecurity.com/>
- **Cyber Security Issues in Auto Transport: Understanding Risks and Threats**
<https://cybersecuritynews.com/>
- **'SIEM Sprawl' Makes It Tough for Security Teams to Detect What Matters**
<https://www.secureworld.io/>
- **Crocodilus Android Malware Expands Globally, Targets Banks and Crypto Wallets**
<https://thehackernews.com/>
- **Triada Malware Resurfaces on Counterfeit Android Phones, Infects Thousands**
<https://thehackernews.com/>
- **Android and iOS Under Siege: Spyware Campaigns Exploit Fake App Downloads**
<https://thehackernews.com/>
- **SuperCard X Malware Hijacks Contactless Payments via NFC**
<https://thehackernews.com/>

Notes

This image shows a single sheet of white paper with horizontal ruling lines. The lines are evenly spaced and run across the width of the page. There are no margins, text, or other markings on the paper.

This image shows a full page of blank white paper with horizontal ruling lines. The lines are evenly spaced and run across the width of the page, providing a guide for writing. There are no margins, text, or other markings on the paper.

This image shows a single sheet of white paper with horizontal ruling lines. The lines are evenly spaced and run across the width of the page. There are no margins, text, or other markings on the paper.



Feedback/Contribution

**Suggestions, feedback and contributions are welcome at
newsletter@nciipc.gov.in**

**Copyright
NCIIPC, Government of India**

Disclaimer

NCIIPC does not endorse any vendor, product or service. The content of the newsletter is for informational purpose only. Readers may validate the information on their own.